



Xibalba

Threat Modeling Security Assessment

Prepared for: Xibalba Interactive

Prepared by: Jeevee Balangan

Security Analysis Report

Date: March 23, 2025



Executive Summary

Threat Model Overview

Xibalba Interactive's critical assets: like game source code, payment systems, and user data: face risks from vulnerabilities in its development environment, public-facing web apps, and administrative controls. These gaps expose the company to phishing, reconnaissance, and direct attacks.

The threat model identifies three major attackers: hackers seeking easy targets, organized cybercriminals, and nation-state actors. These groups could exploit Xibalba's vulnerabilities to steal data, disrupt services, or damage its reputation. Fixing these gaps is essential to keeping operations secure and maintaining player trust.

Solution Roadmap Overview

To protect Xibalba's assets and reduce risks, we recommend solutions tailored to their needs:

- **Honeypots:** Honeyfiles on shared drives will flag unauthorized access and protect sensitive data.
- **Data Sources:** Monitoring file access ensures anomalies are caught quickly to prevent breaches.
- **Mitigations:** Phishing training empowers employees to recognize and stop attacks before they succeed.

These solutions provide immediate value, addressing critical gaps while building a foundation for stronger defenses. They are practical, effective, and aligned with Xibalba's business needs, ensuring their systems and players stay safe.





Threat Model for Xibalba Interactive



Threat Actors



Threat Actors

1. CYBERCRIMINALS

Motivations: Financial gain through data theft or exploitation. Cybercriminals target Xibalba's billing information, user credentials, and exposed vulnerabilities for monetary profit.

Typical Attacks:

- Exploiting web application vulnerabilities, such as XSS in the guestbook feature.
- Launching phishing campaigns to harvest user and employee credentials.

SCENARIO: Exploiting XSS vulnerabilities in the guestbook feature.

- **Details:** Cybercriminals use stored XSS to inject malicious scripts, potentially stealing user data or redirecting users to phishing sites.
- **TTPs: T1190:** Exploit Public-Facing Application; **T1566.001:** Spear Phishing Link.

SCENARIO: Credential theft via phishing campaigns targeting employees.

- **Details:** Attackers send spear-phishing emails to compromise employee accounts, gaining unauthorized access to sensitive systems.
- **TTPs: T1566:** Spear Phishing Attachments; **T1552:** Unsecured Credentials.

2. NATION STATE ACTORS

Motivations: Espionage or disruption of operations. Nation-state actors may exploit Xibalba's infrastructure due to its popularity among U.S. government employees.

Typical Attacks:

- Leveraging leaked IPs to gain unauthorized access to development servers.
- Intercepting and decrypting private in-game communications.

SCENARIO: Exploiting leaked IPs to access development servers.

- **Details:** Attackers use public IP leaks and exposed directories to access proprietary source code or sensitive internal data.
- **TTPs: T1590:** Gather Victim Network Information; **T1555.003:** Credential Dumping.

SCENARIO: Intercepting private in-game chats.

- **Details:** Nation-state actors attempt to decrypt encrypted chat systems to monitor communications among key users.
- **TTPs: T1027:** Obfuscated Files or Information; **T1530:** Data from Cloud Storage.

3. INSIDER THREATS

Motivations: Disgruntled employees or contractors seeking revenge or financial benefit. Insiders have access to sensitive information and can misuse it.

- **Typical Attacks:**

- Stealing proprietary game source code via `.git` directory leaks.
- Misusing shared credentials for unauthorized system access.

SCENARIO: Accessing exposed `.git` directories to steal source code.

- **Details:** Insiders use leaked or improperly secured directories to obtain proprietary code, potentially selling it to competitors.
- **TTPs:** *T1195.002*: Compromise Software Supply Chain; *T1070*: Indicator Removal on Host.

SCENARIO: Misusing shared credentials for unauthorized access.

- **Details:** Insiders exploit the lack of segmented credential controls to access systems beyond their scope.
- **TTPs:** *T1133*: External Remote Services; *T1098*: Account Manipulation.



Attack Surface

Attack Surface

 Attack Surface	1
Admin Credentials.....	1
API Endpoints.....	1
API Logs.....	1
Development Server.....	1
End Users.....	2
IT Administrators.....	2
Payment Gateway Software.....	2
Payment Processing Server.....	2
Public Facing IP.....	2
Public Website Server.....	2
Source Code.....	2
Source Code Repository.....	2
Transaction Data.....	3
User Credentials.....	3
Web App Codebase.....	3

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
Admin Credentials	Admin Credentials, Development Servers	• T1552: Unsecured Credentials • T1098: Account Manipulation	4 (Like... ▾)	5 (Cata... ▾)
API Endpoints	API Server, API Logs	• T1027: Obfuscated Files or Information • T1190: Exploit Public-Facing Application	4 (Like... ▾)	4 (Major) ▾
API Logs	Billing Subscriptions, API Server	• T1189: Drive-by Compromise • T1590: Gather Victim Network Information	3 (Pos... ▾)	3 (Mod... ▾)
Development Server	Game Source Code, Development Servers	• T1195.002: Compromise Software Supply Chain • T1590: Gather Victim	3 (Pos... ▾)	5 (Cata... ▾)

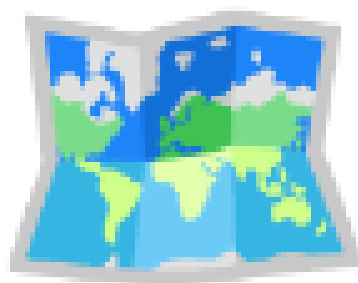
Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
		Network Information		
End Users	Player Interface	• T1566.001: Spear Phishing Link • T1190: Exploit Public-Facing Application	3 (Pos... ▾)	3 (Mod... ▾)
IT Administrators	Admin Credentials	• T1070: Indicator Removal on Host • T1027: Obfuscated Files or Information	3 (Pos... ▾)	4 (Major) ▾
Payment Gateway Software	Billing Subscriptions	• T1190: Exploit Public-Facing Application • T1565.001: Data Manipulation	3 (Pos... ▾)	4 (Major) ▾
Payment Processing Server	Billing Subscriptions	• T1190: Exploit Public-Facing Application • T1555.003: Credential Dumping	3 (Pos... ▾)	5 (Cata... ▾)
Public Facing IP	Development Servers, API Server	• T1590: Gather Victim Network Information • T1189: Drive-by Compromise	4 (Like... ▾)	4 (Major) ▾
Public Website Server	Player Interface	• T1190: Exploit Public-Facing Application • T1566.001: Spear Phishing Link	4 (Like... ▾)	4 (Major) ▾
Source Code	Game Source Code	• T1590: Gather Victim Network Information • T1027: Obfuscated Files or Information	3 (Pos... ▾)	5 (Cata... ▾)
Source Code Repository	Game Source Code	• T1070: Indicator Removal on Host • T1189: Drive-by Compromise	3 (Pos... ▾)	4 (Major) ▾

[illegible]

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
		● TTP ID (TTP Name)	1 (Rare) ▾	1 (Insig... ▾
		● TTP ID (TTP Name)	1 (Rare) ▾	1 (Insig... ▾
		● TTP ID (TTP Name)	1 (Rare) ▾	1 (Insig... ▾



Solution Roadmap



Solution Roadmap for Xibalba Interactive

Honey strategies



Honey strategy Solutions:

Honey strategy Solutions:	1
Deploy Honeyfile to shared drives	2
STAKEHOLDERS	2
Executives	2
IT Team	2
Legal	2
GOALS	2
Deploy Honeyfiles	3
Test Honeyfile Detection	3
Monitor Honeyfile Access	3
Deploy honeycred for login alerts	3
STAKEHOLDERS	3
Executives	3
IT Team	3
Legal	3
GOALS	3
Create Honeycred	4
Validate Honeycred Alerts	4
Integrate Honeycred into Incident Response	4
Set Up a Honeyport for SSH	4
STAKEHOLDERS	4
Executives	4
IT Team	4
Legal	4
GOALS	4
Configure Honeyport	4
Test Honeyport Alerts	4
Monitor Honeyport Activity	4
Establish a Honeynet for analysis	5
STAKEHOLDERS	5
Executives	5
IT Team	5
Legal	5
GOALS	5
Deploy Honeynet	5
Analyze Honeynet Logs	5

Update Honeynet Quarterly.....	5
Setup Honeymail for phishing alerts.....	6
STAKEHOLDERS.....	6
Executives.....	6
IT Team.....	6
Legal.....	6
GOALS.....	6
Deploy Honeymail.....	6
Validate Honeymail Alerts.....	6
Monitor Honeymail Usage.....	6
Honeynet with logs monitoring.....	6
STAKEHOLDERS.....	7
Executives.....	7
IT Team.....	7
Legal.....	7
GOALS.....	7
Integrate Logging.....	7
Validate Logging Alerts.....	7
Review and Refine Detection.....	7

 Honeypot Solution #1		
Deploy Honeyfile to shared drives	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
Decoy files placed on shared drives to detect unauthorized access.		
Addresses attack vector(s):	- T1552: Unsecured Credentials	
Protects key asset(s):	- Game Source Code, Billing Subscriptions	
STAKEHOLDERS		
Executives	IT Team	Legal
Reduces risk of data breaches and protects the company's reputation.	IT TEAM Provides IT early detection and improves security operations.HERE.	Ensures compliance with regulatory standards and prevents penalties.
GOALS		
Name	Description	Deadline

Honeypot Solution #1

Deploy Honeyfile to shared drives	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
Decoy files placed on shared drives to detect unauthorized access.		
Addresses attack vector(s):	- T1552: Unsecured Credentials	
Protects key asset(s):	- Game Source Code, Billing Subscriptions	
Deploy Honeyfiles	Set up decoy files on shared drives to detect unauthorized access.	1-Month
Test Honeyfile Detection	Validate honeyfile detection capabilities by simulating unauthorized access.	TBD
Monitor Honeyfile Access	Continuously monitor and generate alerts for interactions with honeyfiles.	TBD

Honeypot Solution #2

Deploy honeycred for login alerts	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
Fake credentials created to alert on unauthorized login attempts.		
Addresses attack vector(s):	- T1555.003: Credential Dumping	
Protects key asset(s):	- Admin Credentials, User Credentials	
STAKEHOLDERS		
Executives	IT Team	Legal
Reduces risks of credential compromise, protecting financial data.	Strengthens IT’s detection capabilities against unauthorized access.	Honeycreds enhance detection capabilities without adding complexity, giving your team clear and actionable alerts.
GOALS		
Name	Description	Deadline

Create Honeycred	Set up decoy credentials in user directories to detect unauthorized login attempts	2-Weeks
Validate Honeycred Alerts	Test honeycred alerts by simulating phishing or brute force login attempts.	2-3 weeks
Integrate Honeycred into Incident Response	Ensure honeycred alerts are automatically logged and flagged in incident response workflows.	TBD

👑 Honeypot Solution #3		
Set Up a Honeyport for SSH	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Decoy SSH port to detect and log unauthorized probing attempts.		
Addresses attack vector(s):	- T1590: Gather Victim Network Information	
Protects key asset(s):	- Development Servers, API Server	
STAKEHOLDERS		
Executives	IT Team	Legal
Honeyports protect critical systems by detecting unauthorized probes early, reducing downtime and business impact.	Honeyports automate probe detection, saving team time and providing consistent alerts for network activity.	Monitoring SSH activity with honeyports ensures compliance with cybersecurity frameworks and enhances audit readiness.
GOALS		
Name	Description	Deadline
Configure Honeyport	Set up a decoy SSH port to detect probing activity.	1-Week
Test Honeyport Alerts	Simulate SSH scans to validate detection and logging of unauthorized access attempts.	2- Weeks
Monitor Honeyport Activity	Continuously monitor honeyport logs to identify patterns of probing or exploitation attempts.	2-3 Weeks

--	--	--

Honeypot Solution #4

Establish a Honeynet for Analysis	Difficulty: 3 (Hard) ▾	Priority: 3 (High) ▾
A network of honeypots simulating vulnerable systems to monitor attackers.		
Addresses attack vector(s):	- T1189: Drive-by Compromise, T1195.002	
Protects key asset(s):	- Source Code, Development Servers	
STAKEHOLDERS		
Executives	IT Team	Legal
This prevents costly breaches by detecting web-based exploits early and ensuring intellectual property remains secure.	Honeynets simplify exploit detection, reducing the burden of manual monitoring while protecting public-facing apps.	This ensures compliance with regulatory standards by providing logs and evidence of proactive monitoring efforts.
GOALS		
Name	Description	Deadline
Deploy Honeynet	Set up a network of honeypots to simulate vulnerable environments and monitor attacker behavior.	2-Months
Analyze Honeynet Logs	Review honeynet logs to understand attack patterns and refine defenses.	2-3 Months
Update Honeynet Quarterly	Regularly update honeynet configurations to mimic evolving production environments and improve detection.	TBD

Honeypot Solution #5

Setup Honeymail for phishing alerts	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
Decoy email accounts used to detect phishing campaigns targeting the company.		
Addresses attack vector(s):	- T1566.001: Spear Phishing Link	
Protects key asset(s):	- Billing Subscriptions, Admin Credentials	
STAKEHOLDERS		
Executives	IT Team	Legal
Honeymail reduces risks of phishing attacks that could harm the company’s reputation or result in financial losses.	This streamlines phishing detection, providing clear insights and reducing the need for manual investigation.	Honeymail ensures compliance with phishing-related regulations, reducing liability and strengthening documentation.
GOALS		
Name	Description	Deadline
Deploy Honeymail	Set up decoy email accounts to detect phishing campaigns targeting employees.	1-2 Weeks
Validate Honeymail Alerts	Test honeymail by simulating phishing attempts and ensuring alert functionality.	1-2 Weeks
Monitor Honeymail Usage	Regularly review honeymail interactions to identify potential phishing trends or targeted attacks.	TBD



Honeypot Solution #6

Honeynet with logs monitoring	Difficulty: 3 (Hard) ▾	Priority: 3 (High) ▾
Honeynet combined with advanced logging to study attacker behavior.		

Addresses attack vector(s):	- T1190: Exploit Public-Facing Application	
Protects key asset(s):	- API Server, Player Interface	
STAKEHOLDERS		
Executives	IT Team	Legal
This ensures all activity is tracked reliably, reducing costs of post-incident investigations and safeguarding assets.	This simplifies monitoring by automating log analysis, ensuring tampering attempts are detected promptly.	Honeynet logs provide reliable evidence for audits, ensuring compliance with log retention and activity tracking standards.
GOALS		
Name	Description	Deadline
Integrate Logging	Combine honeynet with advanced logging tools to provide detailed attacker analysis.	1- Month
Validate Logging Alerts	Test the integrated logging capabilities to ensure accuracy in detecting attacker activities.	1-2 Months
Review and Refine Detection	Regularly review honeynet logging outputs and refine detection rules based on observed behavior.	TBD



Data sources



Data Sources:

 Data Sources:	1
Monitor File Access.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
Enable File Access Alerts.....	2
Validate Alert Configurations.....	2
Review File Access Logs.....	2
Analyze Network Traffic.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
Implement Network Monitoring.....	3
Test Traffic Alerts.....	3
Establish Baselines.....	3
Monitor Application Logs.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	4
Enable Application Log Alerts.....	4
Automate Log Reviews.....	4
Validate Logging Framework.....	4
Monitor Cloud File Access.....	4
STAKEHOLDERS.....	4
Executives.....	4
IT Team.....	4
Legal.....	4
GOALS.....	4
Implement Cloud Monitoring.....	4
Validate Access Alerts.....	4

Review Cloud Activity Logs.....	5
Analyze Reconnaissance.....	5
STAKEHOLDERS.....	5
Executives.....	5
IT Team.....	5
Legal.....	5
GOALS.....	5
Deploy Recon Detection Tools.....	5
Test Recon Alerts.....	5
Analyze Trends.....	5

 Data Source Solution #1		
Monitor File Access	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Detects suspicious file access activities related to credential extraction.		
Addresses attack vector(s):	- T1555.003: Credential Dumping	
STAKEHOLDERS		
Executives	IT Team	Legal
Protects sensitive credentials and prevents theft.	Provides IT clear indicators of credential misuse.	Ensures compliance with data security standards.
GOALS		
Name	Description	Deadline
Enable File Access Alerts	Set up monitoring tools to detect unauthorized access to critical files.	1- Month
Validate Alert Configurations	Test monitoring and alert configurations to ensure accurate detection of access anomalies.	1-2 Months
Review File Access Logs	Periodically review logs to identify trends or unauthorized access attempts.	TBD



Data Source Solution #2

Analyze Network Traffic

Difficulty: 3 (Hard) ▾

Priority: 3 (High) ▾

Detects exploitation attempts targeting public-facing systems and applications.

Addresses attack vector(s):

- T1190: Exploit Public-Facing Application

STAKEHOLDERS

Executives

IT Team

Legal

Protects external assets from breaches and service outages.

Enhances IT's ability to detect external attacks early.

Ensures compliance with external system monitoring.

GOALS

Name

Description

Deadline

Implement Network Monitoring

Deploy tools to analyze traffic and detect unusual patterns or large data transfers.

2- Months

Test Traffic Alerts

Simulate network scenarios to validate detection and alert triggers for anomalies.

2-3 Months

Establish Baselines

Define normal traffic patterns to improve anomaly detection accuracy.

TBD



Data Source Solution #3

Monitor Application Logs

Difficulty: 2 (Medium) ▾

Priority: 3 (High) ▾

Identifies potential phishing attempts through log analysis.

Addresses attack vector(s):

- T1566: Phishing

STAKEHOLDERS

Executives

IT Team

Legal

Protects employees and user data from phishing risks.

Simplifies IT's ability to detect targeted campaigns.

Helps meet compliance with employee protection standards.

GOALS		
Name	Description	Deadline
Enable Application Log Alerts	Set up monitoring for application logs to detect unauthorized activities or misconfigurations.	1- Month
Automate Log Reviews	Automate log analysis to speed up detection and reduce manual workload.	1- Month
Validate Logging Framework	Test logging configurations to ensure critical application processes are captured and monitored.	TBD

 Data Source Solution #4		
Monitor Cloud File Access	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Detects unauthorized data access in cloud storage systems.		
Addresses attack vector(s):	- T1530: Data from Cloud Storage	
STAKEHOLDERS		
Executives	IT Team	Legal
Protects critical cloud-stored assets.	Provides IT tools to track and stop unauthorized access.	Supports cloud data compliance and access tracking.
GOALS		
Name	Description	Deadline
Implement Cloud Monitoring	Set up monitoring for cloud-stored files to detect unauthorized access or data leakage.	1- Month
Validate Access Alerts	Test monitoring tools to ensure accurate alerts for cloud file	1- Month

	access anomalies.	
Review Cloud Activity Logs	Regularly review cloud logs to identify trends or signs of data exfiltration.	TBD

 Data Source Solution #5		
Analyze Reconnaissance	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Identifies network reconnaissance activities that gather victim network information.		
Addresses attack vector(s):	- T1590: Gather Victim Network Information	
STAKEHOLDERS		
Executives	IT Team	Legal
Prevents early-stage attack planning.	Improves IT's ability to mitigate network risks.	Enhances reporting and compliance with network policies.
GOALS		
Name	Description	Deadline
Deploy Recon Detection Tools	Implement tools to monitor for reconnaissance activities such as port scanning or domain lookups.	2-4 Weeks
Test Recon Alerts	Simulate reconnaissance attempts to validate detection capabilities.	2-4 Weeks
Analyze Trends	Review reconnaissance logs to identify recurring patterns and refine detection strategies.	TBD



Mitigations



Preventive Mitigations:

Preventive Mitigations:	1
User Training.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
Launch Phishing Training.....	2
Conduct Phishing Simulations.....	2
Evaluate Training Results.....	2
Filtering Rules.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	3
Deploy Filtering Rules.....	3
Test Filter Configurations.....	3
Monitor Filtering Effectiveness.....	3
Network Blocking Policies.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
Implement Blocking Policies.....	3
Validate Policies.....	4
Analyze Network Activity.....	4



Preventive Solution #1

User Training	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
Train users to recognize malicious links and phishing attempts.		
Addresses attack vector(s):	- T1566.001	
STAKEHOLDERS		
Executives	IT Team	Legal
Protects the company from phishing attacks, safeguarding sensitive data and reducing risk.	Makes employees the first line of defense, reducing IT's remediation efforts.	Ensures compliance with security training requirements for phishing defense.
GOALS		
Name	Description	Deadline
Launch Phishing Training	Develop and roll out a phishing awareness training program for all employees	TBD
Conduct Phishing Simulations	Run simulated phishing tests to evaluate training effectiveness.	TBD
Evaluate Training Results	Collect feedback and metrics to improve future phishing awareness initiatives.	TBD



Preventive Solution #2

Filtering Rules	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Implement data filtering policies to limit sensitive data leakage.		
Addresses attack vector(s):	- T1590	
STAKEHOLDERS		
Executives	IT Team	Legal
Safeguards critical data and intellectual property by reducing	Simplifies IT's effort to enforce consistent security policies	Mitigates risks related to sensitive data leakage, meeting

exposure to unauthorized entities.	across the network.	compliance requirements.
GOALS		
Name	Description	Deadline
Deploy Filtering Rules	Configure data filtering policies to block unauthorized data sharing.	TBD
Test Filter Configurations	Simulate data-sharing scenarios to ensure accurate policy enforcement.	TBD
Monitor Filtering Effectiveness	Regularly analyze logs to evaluate the effectiveness of implemented rules.	TBD

 Preventive Solution #3		
Network Blocking Policies	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Use network allow/block lists to limit unauthorized scanning activities and reduce the attack surface.		
Addresses attack vector(s):	- T1595	
STAKEHOLDERS		
Executives	IT Team	Legal
Prevents unauthorized reconnaissance by blocking malicious scanning attempts.	Helps IT teams identify and restrict network probes efficiently.	Meets compliance by reducing exposed attack surfaces through proactive network security.
GOALS		
Name	Description	Deadline
Implement Blocking Policies	Configure network policies to block unauthorized scanning activity.	TBD

Validate Policies	Test configurations to ensure effective detection and blocking of unauthorized scans.	TBD
Analyze Network Activity	Regularly monitor network logs to identify trends in scanning and improve defenses.	TBD